Полная авторизация. Предварительный процесс

Сценарии:

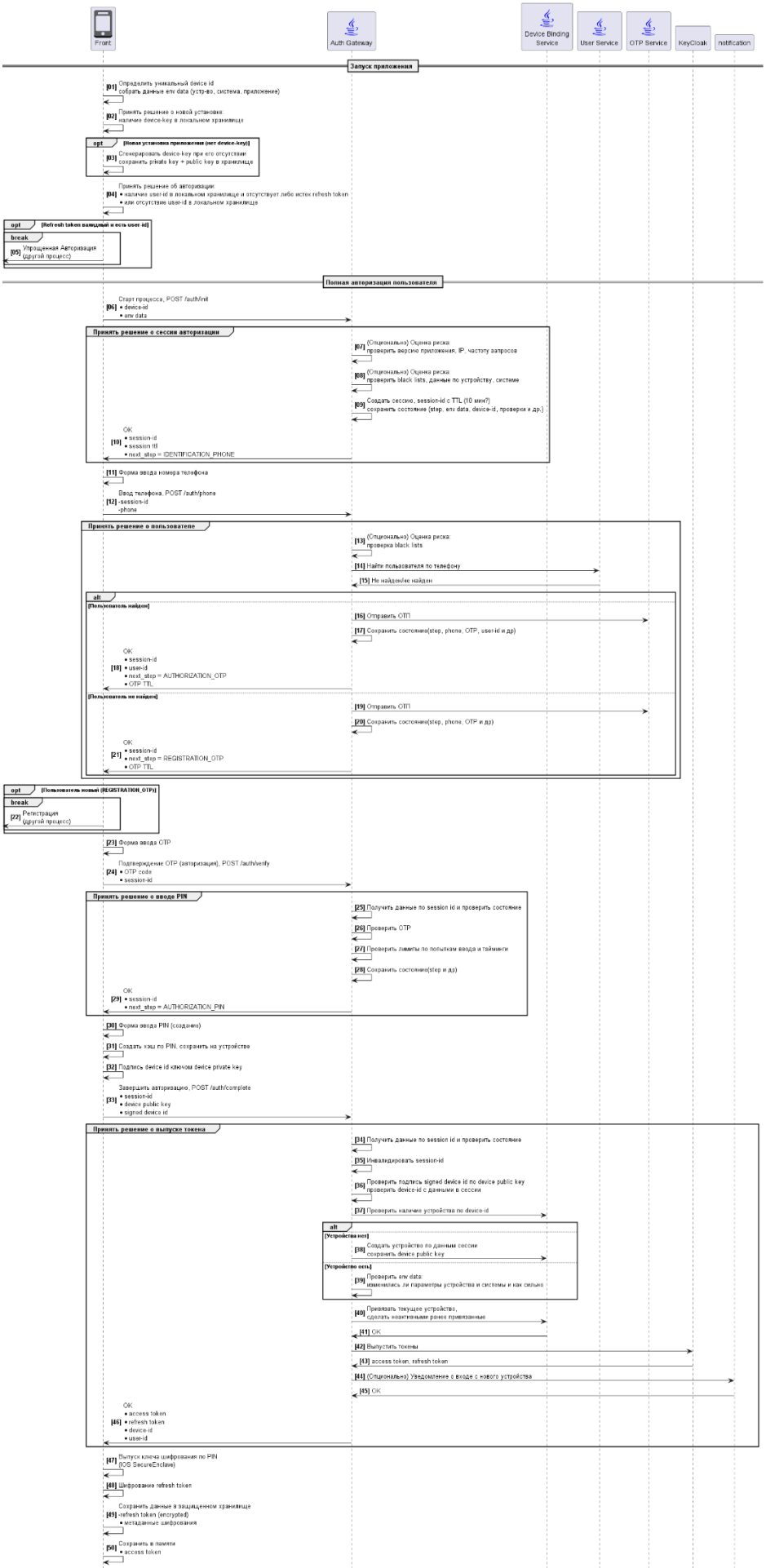
- первая установка приложения, пользователь зарегистрирован
- авторизация второго пользователя в установленном приложении

Plant UML

```
@startuml

!include <tupadr3/devicons/java>
!include <aws/General/mobileclient/mobileclient>
!include <tupadr3/devicons/database>
!include <tupadr3/devicons/codepen>
!include <tupadr3/devicons/redis>

participant "<$mobileclient>\nFront" as frontend
participant "<font color=blue><$java>\nAuth Gateway" as auth
participant "<font color=blue><$java>\nDevice Binding\nService" as device
participant "<font color=blue><$java>\nUser Service" as user
participant "<font color=blue><$java>\nOTP Service" as otp
participant "<font color=blue>\nKeyCloak" as idp

autonumber "<b>[00]"
== Запуск приложения ==

  frontend -> frontend: Определить уникальный device id\nсобрать данные env
data (устр-во, система, приложение)

  frontend -> frontend: Принять решение о новой установке:\nналичие device-
key в локальном хранилище

  opt Новая установка приложения (нет device-key)
    frontend -> frontend: Сгенерировать device-key при его
отсутствии\nсохранить private key + public key в хранилище
  end opt

  frontend -> frontend: Принять решение об авторизации:\n*наличие user-id в
локальном хранилище и отсутствует либо истек refresh token\n*или отсутствие
user-id в локальном хранилище

  opt Refresh token валидный и есть user-id
    break
      frontend ->[:Упрощенная Авторизация\n(другой процесс)
    end break
  end opt
```

```
== Полная авторизация пользователя ==

  frontend -> auth: Старт процесса, POST /auth/init\n*device-id\n*env data
  group Принять решение о сессии авторизации
    auth -> auth: (Опционально) Оценка риска: \nпроверить версию приложения,
IP, частоту запросов
    auth -> auth: (Опционально) Оценка риска: \nпроверить black lists, данные
по устройству, системе

    auth -> auth: Создать сессию, session-id с TTL (10 мин?)\nсохранить
состояние (step, env data, device-id, проверки и др.)

    auth -> frontend: OK\n*session-id\n*session ttl\n*next_step =
IDENTIFICATION_PHONE
  end

  frontend -> frontend: Форма ввода номера телефона
  frontend -> auth: Ввод телефона, POST /auth/phone\n-session-id\n-phone
  group Принять решение о пользователе

    auth -> auth: (Опционально) Оценка риска:\nпроверка black lists

    auth -> user: Найти пользователя по телефону
    user -> auth: Не найден/не найден
    alt
      else Пользователь найден
        auth -> otp: Отправить ОТП
        auth -> auth: Сохранить состояние(step, phone, OTP, user-id и др)
        auth -> frontend: OK\n*session-id\n*user-id\n*next_step =
AUTHORIZATION_OTP\n*OTP TTL
      else Пользователь не найден
        auth -> otp: Отправить ОТП
        auth -> auth: Сохранить состояние(step, phone, OTP и др)
        auth -> frontend: OK\n*session-id\n*next_step =
REGISTRATION_OTP\n*OTP TTL
    end
  end


  opt Пользователь новый (REGISTRATION_OTP)
    break
      frontend ->[:Регистрация\n(другой процесс)
    end break
  end opt

    frontend -> frontend: Форма ввода OTP
    frontend -> auth: Подтверждение OTP (авторизация), POST
/auth/verify\n*OTP code\n*session-id
    group Принять решение о вводе PIN
      auth -> auth: Получить данные по session id и проверить состояние
      auth -> auth: Проверить OTP

      auth -> auth: Проверить лимиты по попыткам ввода и тайминги

      auth -> auth: Сохранить состояние(step и др)
```

```
      auth -> frontend: OK\n*session-id\n*next_step = AUTHORIZATION_PIN

    end

    frontend -> frontend: Форма ввода PIN (создание)
    frontend -> frontend: Создать хэш по PIN, сохранить на устройстве
    frontend -> frontend: Подпись device id ключом device private key

    frontend -> auth: Завершить авторизацию, POST /auth/complete\n*session-
id\n*device public key\n*signed device id
    group Принять решение о выпуске токена
      auth -> auth: Получить данные по session id и проверить состояние

      auth -> auth: Инвалидировать session-id

      auth -> auth: Проверить подпись signed device id по device public
key\nпроверить device-id с данными в сессии

      auth -> device: Проверить наличие устройства по device-id
      alt
        else Устройства нет
          auth -> device: Создать устройство по данным сессии\nсохранить
device public key
        else Устройство есть
          auth -> auth: Проверить env data:\nизменились ли параметры
устройства и системы и как сильно
      end

      auth -> device: Привязать текущее устройство,\nсделать неактивными
ранее привязанные
      device -> auth: OK

      auth -> idp: Выпустить токены
      idp -> auth: access token, refresh token

      auth -> notification: (Опционально) Уведомление о входе с нового
устройства
      notification -> auth: OK

      auth -> frontend: OK\n*access token\n*refresh token\n*device-id\n*user-
id

    end

    frontend -> frontend: Выпуск ключа шифрования по PIN\n(IOS SecureEnclave)
    frontend -> frontend: Шифрование refresh token
    frontend -> frontend: Сохранить данные в защищенном хранилище\n-refresh
token (encrypted)\n*метаданные шифрования
    frontend -> frontend: Сохранить в памяти\n*access token
    frontend -> frontend: Сохранить метаданные\n*refresh token
expiration\n*device-id\n*user-id

@enduml
```


Front
Auth Gateway
Device Binding Service
User Service
OTP Service
KeyCloak
notification
Запуск приложения
[01] Опредалить уникальный device id
собрать данные env data (устр-во, система, приложение)
[02] Принять решение о новой установке:
наличие device-key в локальном хранилище
opt [Новая установка приложения (нет device-key)]
[03] Сгенерировать device-key при его отсутствии,
сохранить private key + public key в хранилище
Принять решение об авторизации:
[04] • наличие user-id в локальном хранилище и отсутствует либо истек refresh token
• или отсутствие user-id в локальном хранилище
opt [Refresh token валидный и есть user-id]
break
[05] Упрощенная Авторизация
(другой процесс)
Полная авторизация пользователя
Старт процесса, POST /auth/init
[06] • device-id
• env data
Принять решение о сессии авторизации
[07] (Опционально) Оценка риска:
проверить версию приложения, IP, частоту запросов
[08] (Опционально) Оценка риска:
проверить black lists, данные по устройству, системе
[09] Создать сессию, session-id с TTL (10 мин?)
сохранить состояние (step, env data, device-id, проверки и др.)
OK
[10] • session-id
• session ttl
• next_step = IDENTIFICATION_PHONE
[11] Форма ввода номера телефона
Ввод телефона, POST /auth/phone
[12] -session-id
-phone
Принять решение о пользователе
[13] (Опционально) Оценка риска:
проверка black lists
[14] Найти пользователя по телефону
[15] Не найден/не найден
alt
[Пользователь найден]
[16] Отправить OTP
[17] Сохранить состояние(step, phone, OTP, user-id и др)
OK
[18] • session-id
• user-id
• next_step = AUTHORIZATION_OTP
• OTP TTL
[Пользователь не найден]
[19] Отправить OTP
[20] Сохранить состояние(step, phone, OTP и др)
OK
[21] • session-id
• next_step = REGISTRATION_OTP
• OTP TTL
opt [Пользователь новый (REGISTRATION_OTP)]
break
[22] Регистрация
(другой процесс)
[23] Форма ввода OTP
Подтверждение OTP (авторизация), POST /auth/verify
[24] • OTP code
• session-id
Принять решение о вводе PIN
[25] Получить данные по session id и проверить состояние
[26] Проверить OTP
[27] Проверить лимиты по попыткам ввода и таймиги
[28] Сохранить состояние(step и др)
OK
[29] • session-id
• next_step = AUTHORIZATION_PIN
[30] Форма ввода PIN (создание)
[31] Создать хэш по PIN, сохранить на устройстве
[32] Подпись device id ключом device private key
Завершить авторизацию, POST /auth/complete
[33] • session-id
• device public key
• signed device id
Принять решение о выпуске токена
[34] Получить данные по session id и проверить состояние
[35] Инвалидировать session-id
[36] Проверить подпись signed device id по device public key
проверить device-id с данными в сессии
[37] Проверить наличие устройства по device-id
alt
[Устройства нет]
[38] Создать устройство по данным сессии
сохранить device public key
[Устройство есть]
[39] Проверить env data:
изменились ли параметры устройства и системы и как сильно
[40] Привязать текущее устройство,
сделать неактивными ранее привязанные
[41] OK
[42] Выпустить токены
[43] access token, refresh token
[44] (Опционально) Уведомление о входе с нового устройства
[45] OK
OK
[46] • access token
• refresh token
• device-id
• user-id
[47] Выпуск ключа шифрования по PIN
(IOS SecureEnclave)
[48] Шифрование refresh token
Сохранить данные в защищенном хранилище
[49] -refresh token (encrypted)
• метаданные шифрования
[50] Сохранить в памяти
• access token